

API de Integração Externa

Módulo de Pagamentos PIX

Versão 1.1

1. Visão Geral

Este documento descreve a integração entre o servidor wssh-vpn e aplicações externas no contexto do módulo de pagamentos PIX.

Fluxo A — Servidor → Externo	Fluxo B — Externo → Servidor
Após um pagamento ser confirmado, o servidor envia automaticamente um POST para a URL configurada em <code>pix_external_notify_url</code> .	A aplicação externa pode criar cobranças e notificar confirmações/cancelamentos via dois endpoints dedicados.

2. Configuração do Servidor

Variável	Tipo	Descrição
<code>pix_external_notify_url</code>	string (URL)	URL que recebe POST após confirmação de pagamento. Deve ser HTTPS em produção.
<code>pix_webhook_secret</code>	string	Segredo HMAC-SHA256 compartilhado. Quando definido, todas as requisições externas exigem X-Signature.

Segurança obrigatória em produção

Defina `pix_webhook_secret` com ao menos 32 caracteres aleatórios. Sem ele, qualquer requisição para os endpoints externos será aceita sem autenticação.

3. Endpoints da Aplicação Externa

Todos os endpoints abaixo são destinados exclusivamente a sistemas externos. O endpoint interno `/api/pagamento/iniciar` não deve ser exposto a clientes finais.

Endpoint	Método	Descrição
POST <code>/api/pagamentos/externos/iniciar</code>	POST	Cria uma nova cobrança PIX. Valor e dias de acesso são sempre lidos do banco — o cliente não controla o preço.
POST <code>/api/pagamentos/externos</code>	POST	Notifica o servidor sobre confirmação ou cancelamento de um pagamento já existente.
GET <code>/api/pagamento/status/{id}</code>	GET	Consulta o status de um pagamento. Após confirmação, retorna usuário e senha do acesso criado.

3.1 Criar Cobrança PIX

Endpoint

Atributo	Valor
URL	POST <code>/api/pagamentos/externos/iniciar</code>
Autenticação	X-Signature (HMAC-SHA256 do corpo) — obrigatório quando <code>pix_webhook_secret</code> estiver configurado
Content-Type	application/json
Idempotência	Opcional: envie X-Idempotency-Key para evitar cobranças duplicadas em tentativas
Rate Limit	10 req/min por IP

Valor mínimo: R\$ 0,50 | Máximo: R\$ 10.000,00

O campo `plano_tipo` é um rótulo livre — não consulta o banco VPN e não cria acesso. O servidor gera o PIX, aguarda a confirmação do gateway e notifica a app externa.

Corpo da requisição

{
"cliente_nome": "João da Silva", // obrigatório
"cliente_email": "joao@email.com", // obrigatório

"cliente_tel":	"11999998888",	// opcional
"plano_tipo":	"mensal",	// obrigatório – rótulo livre para exibição
"valor":	49.90,	// obrigatório – mín. R\$ 0,50
"plano_dias":	30	// opcional – apenas informativo, não cria acesso VPN
}		

Campo	Obrigatório?	Descrição
cliente_nome	Sim	Nome do cliente. Enviado na notificação para exibição no painel.
cliente_email	Sim	E-mail do cliente. Enviado na notificação para identificação.
cliente_tel	Não	Telefone (8–20 chars, dígitos e símbolos +()-).
plano_tipo	Sim	Rótulo livre — sem vínculo com o banco VPN. Exibido no painel da app externa (ex: "mensal", "gold", "teste7d").
valor	Sim	Valor em reais definido pelo integrador. Mínimo R\$ 0,50, máximo R\$ 10.000,00.
plano_dias	Não	Informativo — enviado na notificação. Não cria nem gerencia acesso VPN.

Resposta de sucesso (HTTP 200)

{		
"success":	true,	
"id":	"a1b2c3d4-e5f6-...",	// pagamento_id – guardar para consultas
"txid":	"abc123def456...",	
"qrcode_base64":	"iVBORw0KGgo...",	// imagem PNG do QR Code em base64
"payload_emv":	"00020101...",	// string copia-e-cola PIX
"valor":	49.90,	
"plano_tipo":	"mensal",	
"plano_dias":	30,	
"expira_em":	"2025-03-15T15:30:00Z"	// expiração do QR Code (1 hora)
}		

Exemplo de chamada — Python

import hmac, hashlib, json, requests
SECRET = "seu_segredo_aqui"

```

URL      = "https://seuservidor.com/api/pagamentos/externos/iniciar"

payload = {
    "cliente_nome": "João da Silva",
    "cliente_email": "joao@exemplo.com",
    "senha_cliente": "senhaSegura123",
    "plano_tipo":    "mensal",
}

body = json.dumps(payload, separators=(",", ":")).encode()
sig  = hmac.new(SECRET.encode(), body, hashlib.sha256).hexdigest()

resp = requests.post(URL, data=body, headers={
    "Content-Type":    "application/json",
    "X-Signature":     sig,
    "X-Idempotency-Key": "pedido-uuid-123", # opcional
})
data = resp.json()
print(data["id"])          # pagamento_id
print(data["payload_emv"]) # string copia-e-cola

```

Exemplo de chamada — Node.js

```

const crypto = require('crypto');
const axios  = require('axios');

const SECRET = "seu_segredo_aqui";
const URL    = "https://seuservidor.com/api/pagamentos/externos/iniciar";

const payload = JSON.stringify({
    cliente_nome: "João da Silva",
    cliente_email: "joao@exemplo.com",
    senha_cliente: "senhaSegura123",
    plano_tipo:    "mensal",
});

const sig = crypto.createHmac("sha256", SECRET)
    .update(payload).digest("hex");

const { data } = await axios.post(URL, payload, {
    headers: {
        "Content-Type":    "application/json",
        "X-Signature":     sig,
        "X-Idempotency-Key": "pedido-uuid-123",
    }
});

```

```

    }
  });
  console.log(data.id);           // pagamento_id
  console.log(data.payload_emv); // copia-e-cola

```

3.2 Notificar Confirmação ou Cancelamento

Endpoint

Atributo	Valor
URL	POST /api/pagamentos/externos
Autenticação	X-Signature (HMAC-SHA256) — obrigatório quando pix_webhook_secret configurado
Content-Type	application/json
Rate Limit	10 req/min por IP

Corpo da requisição

```

{
  "pagamento_id": "a1b2c3d4-e5f6-...", // obrigatório se txid não informado
  "txid": "abc123...", // alternativa ao pagamento_id
  "status": "pago", // obrigatório: "pago" | "cancelado"
  "observacoes": "Ref. pedido #4521" // opcional, máx. 500 chars
}

```

Resposta de sucesso (HTTP 200)

```

{ "success": true, "mensagem": "Pagamento confirmado com sucesso", "pagamento_id": "..."}

```

3.3 Consultar Status do Pagamento

Este endpoint é auxiliar. O fluxo primário de confirmação é event-driven: quando o gateway (EFÍ, Mercado Pago) confirma o pagamento via webhook, o servidor processa a confirmação e imediatamente envia um POST para pix_external_notify_url (seção 4). A app externa não precisa fazer polling — ela recebe a notificação automaticamente.

Quando usar este endpoint

Use GET /api/pagamento/status/{id} como fallback: para verificar o estado inicial após criar a cobrança, para reconciliação de pagamentos, ou quando a notificação automática não foi recebida por algum motivo (timeout, indisponibilidade temporária da sua URL).

Atributo	Valor
URL	GET /api/pagamento/status/{pagamento_id}
Acesso	Público — sem autenticação necessária

Resposta pendente

```
{ "id": "...", "status": "pendente", "valor": 49.90, "pago": false, "expira_em": "...", }
```

Resposta após confirmação (inclui credenciais)

As credenciais ficam disponíveis neste endpoint, mas na prática a app externa já as recebe via notificação automática (seção 4) no campo cliente_email e pode optar por armazenar localmente sem precisar consultar aqui.

```
{
  "id": "a1b2c3d4-...",
  "status": "pago",
  "valor": 49.90,
  "pago": true,
  "usuario": "João da Silva",
  "senha": "senhaSegura123"
}
```

Segurança das credenciais

O campo senha só é retornado quando status = "pago". Nunca exponha essa rota em um frontend que armazene o pagamento_id em URL pública.

4. Fluxo A — Notificação do Servidor para App Externa

Quando ocorre

O servidor envia um POST para pix_external_notify_url sempre que um pagamento é confirmado, independentemente da origem (gateway EFÍ, Mercado Pago, admin manual ou endpoint externo).

Requisição enviada pelo servidor

Atributo	Valor
Método	POST
URL destino	pix_external_notify_url
Content-Type	application/json
User-Agent	wssh-vpn-pagamento/1.0
X-Signature	HMAC-SHA256 do corpo (hex) — presente se pix_webhook_secret estiver definido
Timeout	10 segundos

Corpo da notificação

{
"evento": "pagamento.confirmado",
"versao": "1.0",
"timestamp": "2025-03-15T14:32:00Z",
"pagamento_id": "a1b2c3d4-e5f6-...",
"txid": "abc123def456...",
"valor": 49.90,
"status": "pago",
"gateway": "efi",
"plano_tipo": "mensal", // rótulo informado na criação
"cliente_nome": "João da Silva",
"cliente_email": "joao@exemplo.com",
"cliente_tel": "11999998888",
"origem": "externo", // "externo" "interno"
"expira_em": "2025-03-15T15:30:00Z"
}

Como validar X-Signature

Python

import hmac, hashlib
def verificar(body: bytes, sig: str, secret: str) -> bool:
mac = hmac.new(secret.encode(), body, hashlib.sha256)
return hmac.compare_digest(mac.hexdigest(), sig)

Node.js

```
const crypto = require('crypto');
function verificar(body, sig, secret) {
  const mac = crypto.createHmac("sha256", secret).update(body).digest("hex");
  return crypto.timingSafeEqual(Buffer.from(mac), Buffer.from(sig));
}
```

PHP

```
function verificar($body, $sig, $secret): bool {
  return hash_equals(hash_hmac("sha256", $body, $secret), $sig);
}
```

Resposta esperada

Responda com HTTP 200 imediatamente e processe a lógica de negócio de forma assíncrona. O servidor não faz reenvio em caso de falha — implemente uma fila ou log de retentativas na sua aplicação se necessário.

5. Boas Práticas de Segurança

1. **HTTPS obrigatório** — nunca use HTTP em produção para nenhum dos endpoints.
2. **Configure pix_webhook_secret** — use ao menos 32 caracteres aleatórios.
3. **Comparação de tempo constante** — use `hmac.compare_digest` / `timingSafeEqual` / `hash_equals` para evitar timing attacks.
4. **Idempotência** — envie `X-Idempotency-Key` em `/iniciar` para evitar cobranças duplicadas em caso de tentativa por timeout.
5. **Guarde pagamento_id** — armazene o ID retornado por `/iniciar` para rastreamento, polling e reconciliação.
6. **Não exponha senha_cliente em URL** — a senha é retornada apenas após confirmação; trafegue-a somente via HTTPS e armazene com segurança.

6. Fluxo Completo de Integração

Passo	Descrição
1. Criar cobrança	App externa chama POST <code>/api/pagamentos/externos/iniciar</code> com dados do cliente e plano_tipo. Recebe id, qrcode_base64, payload_emv e valor.
2. Exibir QR Code	App exibe qrcode_base64 como <code></code> e payload_emv como campo copia-e-cola para o cliente pagar no app bancário.

Passo	Descrição
3. Aguardar notificação	Quando o cliente paga, o gateway (EFÍ / Mercado Pago) confirma via webhook → servidor processa → envia POST automático para pix_external_notify_url. Não é necessário polling.
4a. Confirmação auto	App recebe o POST em pix_external_notify_url com evento="pagamento.confirmado", libera o serviço e envia e-mail de boas-vindas ao cliente.
4b. Confirmação manual	Se sua app receber confirmação por outro canal (ex: gateway próprio), chame POST /api/pagamentos/externos com status="pago".
5. Fallback / reconciliação	Se a notificação não chegar (timeout, indisponibilidade), use GET /api/pagamento/status/{id} para verificar o estado atual.
6. Credenciais prontas	GET /api/pagamento/status/{id} retorna usuario e senha quando pago. Na prática já foram entregues no passo 4a via notificação.

7. Referência Rápida de Endpoints

Método + Rota	Acesso	Descrição
POST /api/pagamentos/externos/iniciar	HMAC	Cria cobrança PIX para app externa. Valor definido pelo integrador.
POST /api/pagamentos/externos	HMAC	Notifica confirmação ou cancelamento de pagamento existente.
GET /api/pagamento/status/{id}	Público	Consulta status do pagamento.
POST /api/pagamento/confirmar/{id}	Admin	Confirma manualmente (painel admin).
POST /api/pagamento/cancelar/{id}	Admin	Cancela um pagamento.

8. Respostas de Erro

HTTP	Situação	Mensagem típica
400	Dados inválidos	"cliente_email inválido" / "plano_tipo inválido ou sem preço configurado"
401	Sem / HMAC inválido	"X-Signature obrigatório" / "assinatura inválida"

HTTP	Situação	Mensagem típica
405	Método errado	"método não permitido"
429	Rate limit	"muitas requisições, aguarde antes de tentar novamente"
502	Erro no gateway PIX	"erro ao gerar cobrança PIX, tente novamente"
500	Erro interno	"erro interno de configuração"